

Management de la Sécurité de l'information

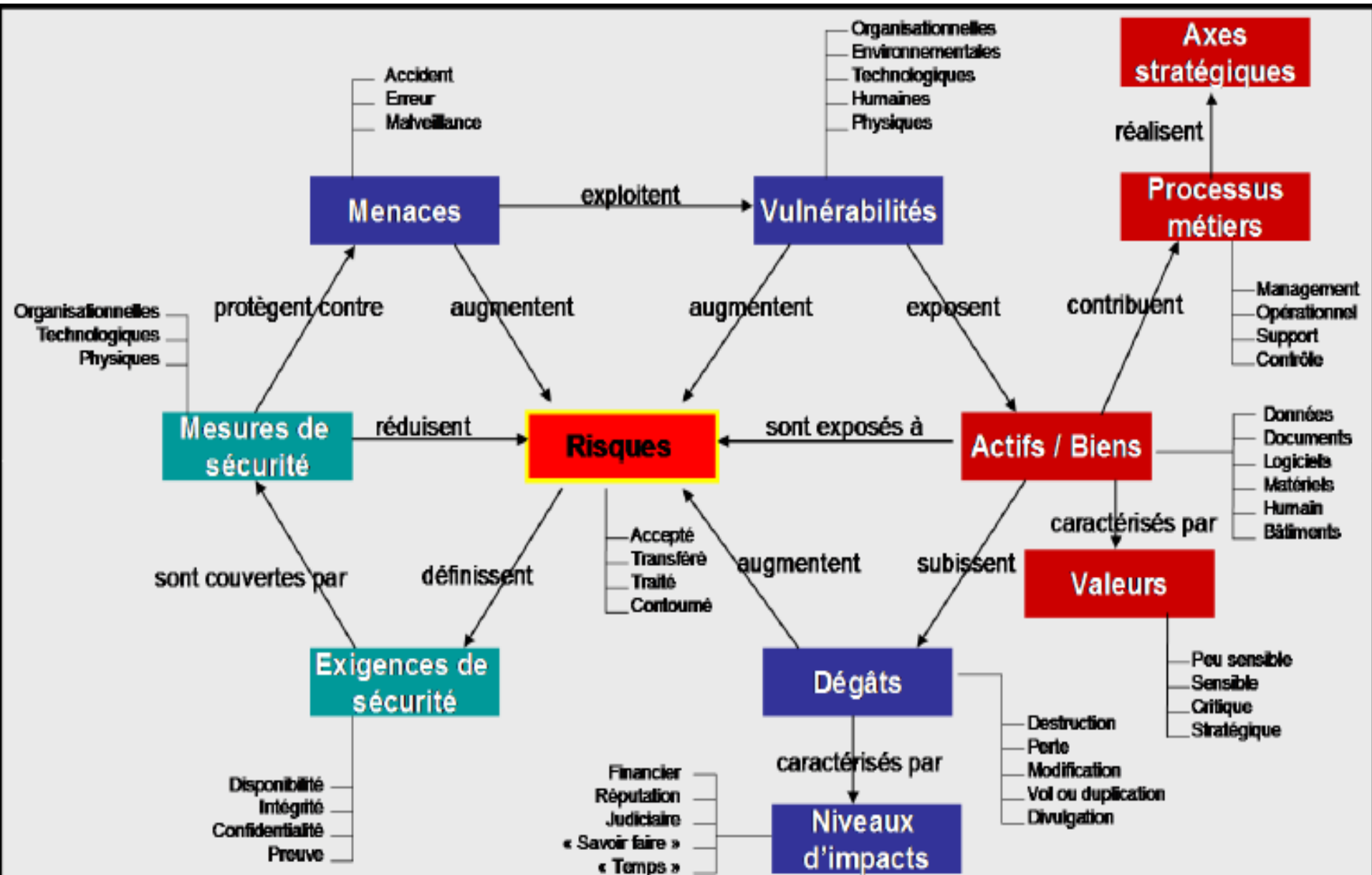
Agenda

- LE RISQUE
- Management de la sécurité des systèmes d'information
- Gestion des risques
- Politique de sécurité
- Audit de Sécurité

Management de la sécurité de l'information

- Gérer la sécurité revient à gérer les risques
- Assurer le compromis entre « protection » et « performance et efficacité »
- Assurer le compromis entre « Coût » et « Efficacité »

Management des risques



Management de la sécurité du SI ... par le bricolage

Antivirus gratuit

**Logiciel de
Récupération
de données suite
à un Incident**

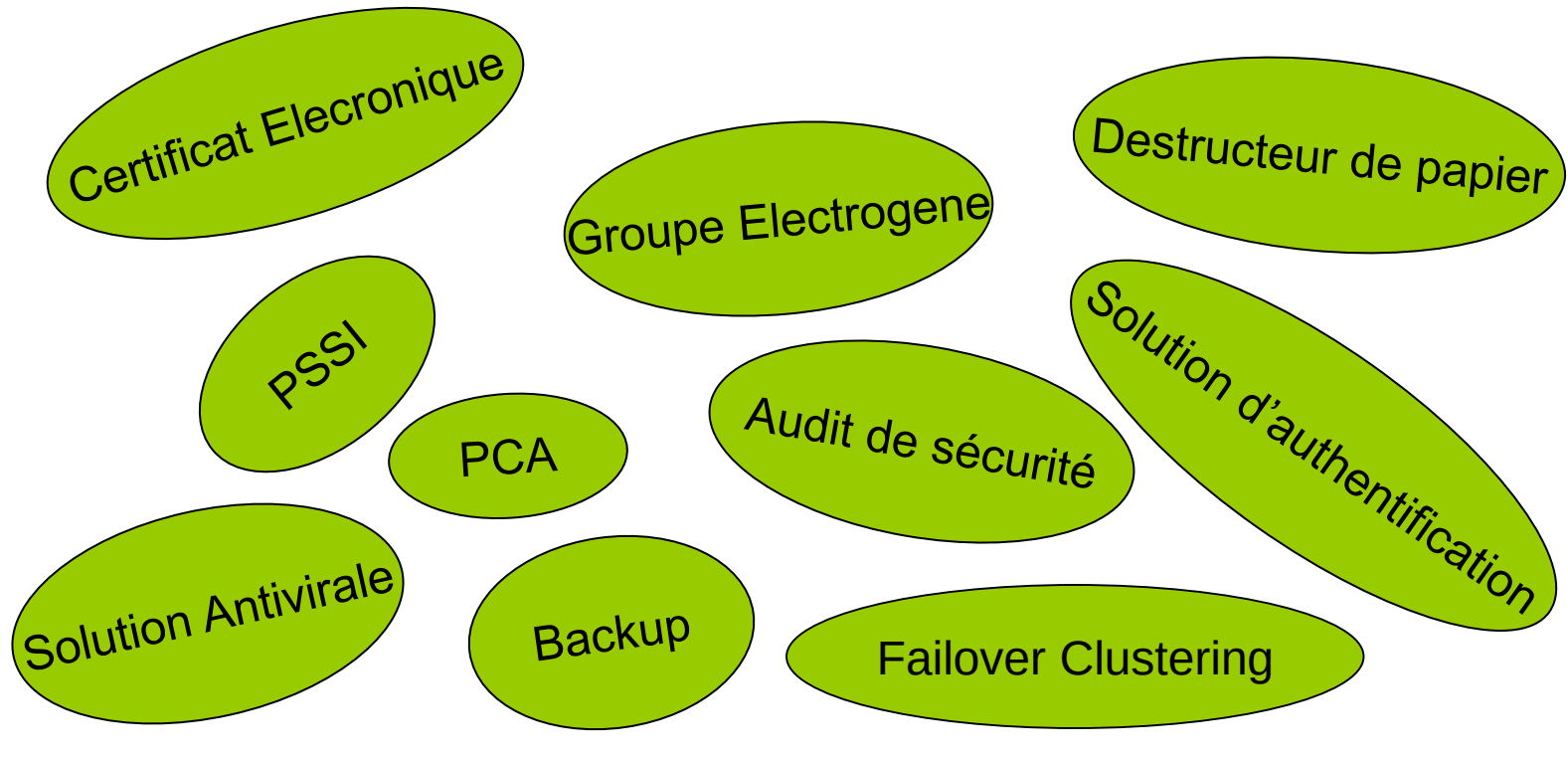


**Suppression
de fichiers douteux**

**Téléchargement
d'un Kit de nettoyage**

Management de la Sécurité du SI ...par l'intuition

Temps



Management basé sur les enjeux de la SSI

Niveau des conséquences potentielles

Adhérence au système d'information

Niveau des impacts internes

Niveau des impacts externes

Sensibilité du patrimoine informationnel

Besoins de disponibilité

Besoins d'intégrité

Besoins de confidentialité

Degré d'exposition aux menaces

Fréquence des incidents SSI

Degré de motivation des attaquants

Moyens des attaquants

Importance des vulnérabilités

Hétérogénéité du système d'information

Ouverture du système d'information

Variabilité du système d'information

Somme des quatre valeurs

De 0 à 2

De 3 à 5

De 6 à 8

De 9 à 10

De 11 à 12

Niveau adéquat de maturité

1 - Pratique informelle : Actions isolées

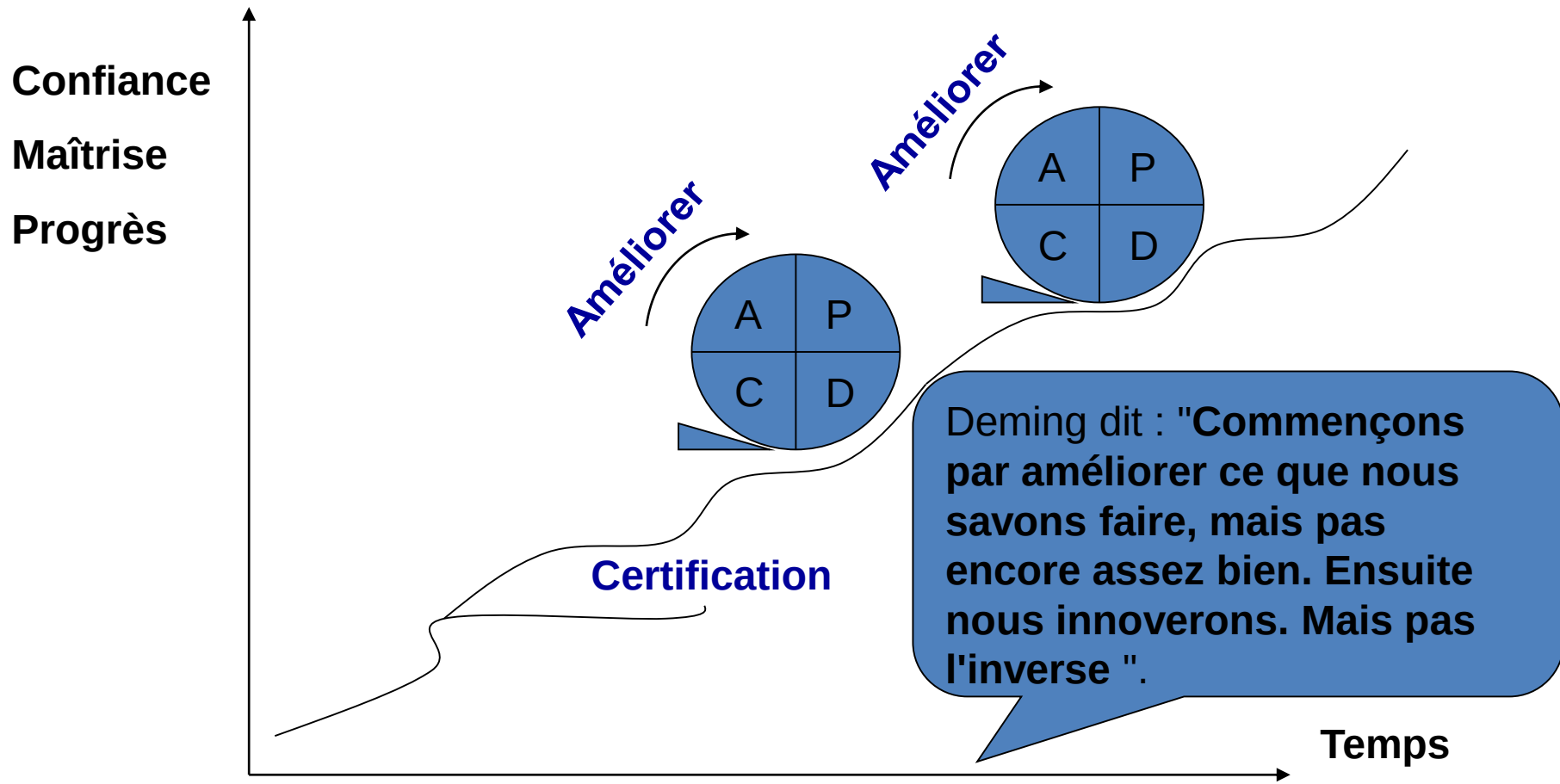
2 - Pratique répétable et suivie : Actions reproductible

3 - Processus définis : Standardisation des pratiques

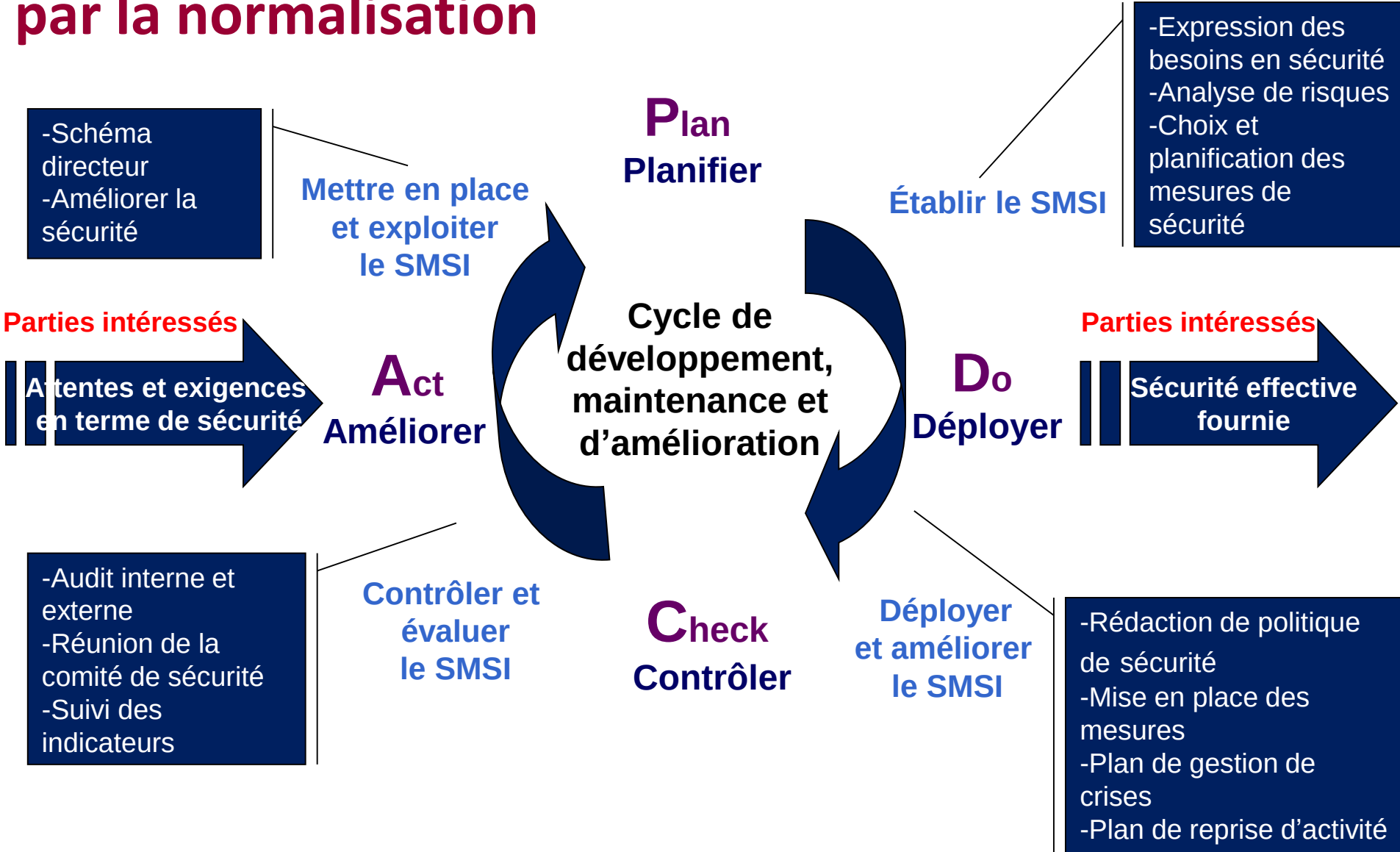
4 - Processus contrôlés : des mesures quantitatives

5 - Processus continuellement optimisés

Management de la Sécurité du SI ... par la normalisation



Management de la Sécurité du SI ... par la normalisation



Pourquoi utiliser une norme pour le management de la sécurité de l'Information?

Organisation: Engagement

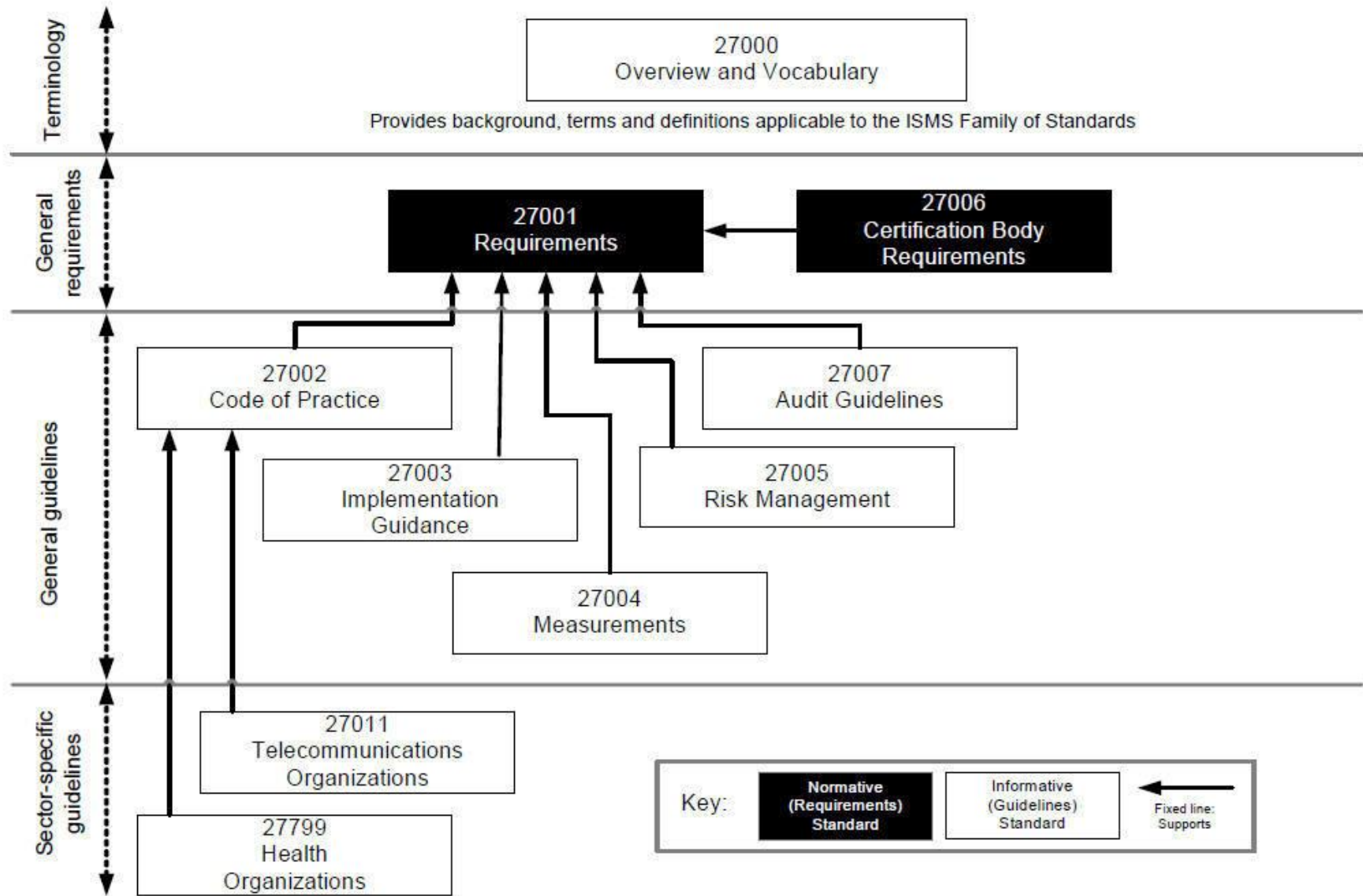
Aspect légal: Conformité

Aspect opérationnel: Gestion de risques

Commercial: Crédibilité et confiance

Finances: Baisse des coûts

La famille ISO 27000



La famille ISO 27000

Norme	Date	Description
ISO 27000	01/2014	Vue d'ensemble et vocabulaire
ISO 27001	09/2013	Exigences du SMSI
ISO 27002	09/2013	Code de bonne pratique MSI
ISO 27003	02/2010	Guide de mise en œuvre du SMSI
ISO 27004	12/2009	Mesure de l'efficacité du SMSI
ISO 27005	05/2011	Gestion des risques liés à la sécurité de l'information
ISO 27006	11/2011	Exigences pour les organismes procédant à l'audit et à la certification des SMSI
ISO 27007	11/2011	Lignes directrices pour l'audit des SMSI

La famille ISO 27000

Norme	Date	Description
ISO 27031	03/2011	Guide pour la préparation des TIC pour la continuité d'activité
ISO 27032	07/2012	Guide pour la cybersécurité
ISO 27033	01/2013	Sécurité de réseau -- Partie 1: Vue d'ensemble et concepts
ISO 27034	11/2011	Sécurité des applications -- Partie 1: Vue d'ensemble et concepts
ISO 27035	08/2011	Gestion des incidents de sécurité de l'information
ISO 27011	12/2008	Code de bonne pratique MSI pour les organismes de télécommunications
ISO 27799	06/2008	Code de bonne pratique MSI pour la santé
ISO 21827	10/2008	Modèle de maturité de capacité (SSE-CMM®)
...		

ISO27002 v 2013

Domaines

- A.5: Information security policies
- A.6: Organization of information security
- A.7: Human resources security
- A.8: Asset management
- A.9: Access control
- A.10: Cryptography
- A.11: Physical and environmental security
- A.12: Operations security
- A.13: Communication security
- A.14: System acquisition, development, and maintenance
- A.15: Supplier relationships
- A.16: Information security Incident management
- A.17: Information security aspects of business continuity management
- A.18: Compliance

Version 2013 : 114 mesures dans 14 domaines

Version 2005 : 133 mesures dans 11 domaines



SMSI ISO 27001

Etape 1 : Etablissement du SMSI (P)

Etape 2: Mise en œuvre et fonctionnement du SMSI (D)

Etape 3 : Surveillance et réexamen du SMSI (C)

Etape 4 : Maintien et amélioration du SMSI (A)

Etape 5 : Préparation à l'audit de certification

Etape1 : établissement du SMSI (Planifier)

1 Compréhension de l'organisme

- Mission, objectifs, valeurs et stratégies
- Environnements externe et interne
- Principaux processus et activités & Infrastructure IT
- Identification et analyse des parties intéressées
- Identification et analyse des exigences légales, réglementaires & contractuelles
- Clarification des objectifs d'un projet SMSI
- Domaine d'application préliminaire

- Objectifs, priorités et exigences liées au SMSI
- Domaine d'application préliminaire

Etape1 : établissement du SMSI (Planifier)

2 Analyse du système de management existant

- Collecte d'information: entretiens + revue documentaire + observation + outil de balayage
- Analyse des écarts: diagnostic entre les mesures de sécurité existantes et les exigences de la norme ISO 27001 (clauses et contrôles de l'Annexe A)
- Rapport d'analyse des écarts

Rapport d'analyse des écarts

Etape1 : établissement du SMSI (Planifier)

3 Formalisation et approbation du projet SMSI

- Créer un business case (contexte, but et objectifs, sommaire du projet, bénéfices attendus, domaine d'application préliminaire, facteurs critiques de success, plan préliminaire du projet, délais et étapes clés, rôles et responsabilités, ressources nécessaires, budget prévu, contraintes)
- Etablir l'équipe de projet SMSI
- Rédiger le plan de projet SMSI (feuille de route) (charte du projet, approche/stratégie de management du projet, énoncé du contenu du projet avec les livrables du projet et ses objectifs, décomposition du projet, estimation du coût et date début, responsabilités, jalons principaux avec leurs dates prévisionnelles, personnel clé, risques principaux, contraintes, hypothèses, problèmes, décisions en attente)
- Approbation par la direction du projet SMSI

- Rapport Business case
- Plan de projet SMSI

Etape1 : établissement du SMSI (Planifier)

4 Domaine d'application du SMSI

- Définition des frontières organisationnelles du domaine d'application
- Définition des frontières du système d'information
- Définition des frontières physiques
- Définition du domaine d'application du SMSI (caractéristiques clés de l'organisme, processus organisationnels, rôles et responsabilités liés au SMSI, liste des systèmes d'information, liste des actifs informationnels, cartes et plans des sites géographiques, détails et justifications des exclusions)

Domaine d'application du SMSI documenté et approuvé

Etape1 : établissement du SMSI (Planifier)

5 Politiques de sécurité de l'information

- Création de modèles de politiques (annexe D, ISO 27003)
- Définition d'un processus de rédaction d'une politique
- Rédaction de la politique SMSI
- Rédaction de la politique de sécurité de l'information
- Rédaction de politiques de sécurité spécifiques
- Approbation par la direction
- Publication et diffusion
- Formation, communication et sensibilisation
- Contrôle, évaluation et révision

- Politique SMSI
- Politique de sécurité de l'information
- Ensemble des politiques spécifiques

Etape1 : établissement du SMSI (Planifier)

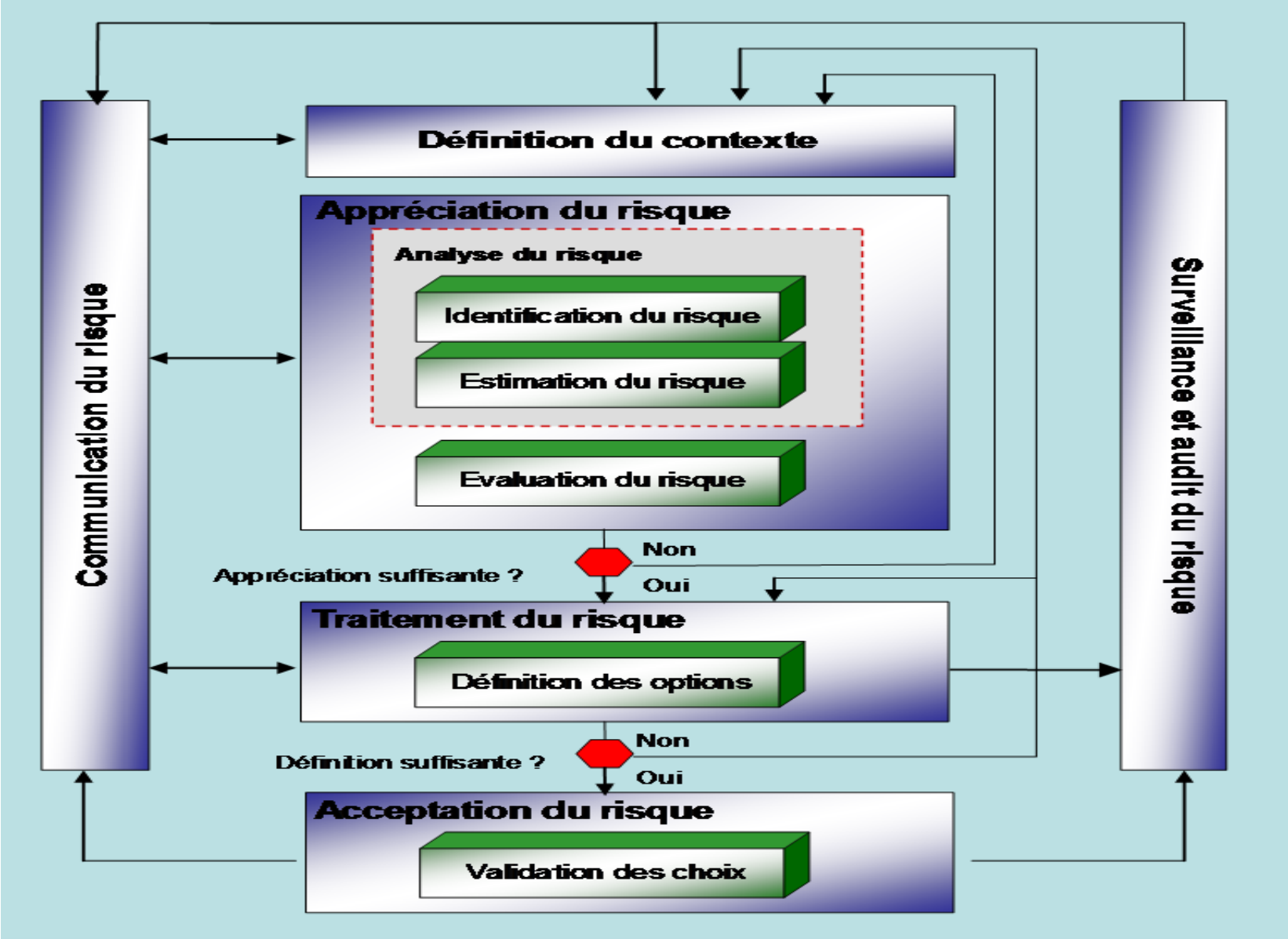
6

Appréciation du risque

- Sélection de l'approche et de la méthodologie d'appréciation du risque
- Identification du risque
- Estimation du risque
- Evaluation du risque
- Traitement du risque
- Acceptation du risque

- Rapport d'appréciation du risque
- Plan de traitement du risque

Gestion des risques selon ISO 27005



Etape1 : établissement du SMSI (Planifier)

7

Déclaration d'applicabilité et autorisation par la direction de mise en œuvre du SMSI

- Sélection des objectifs et mesures applicables
- Justification des mesures sélectionnées
- Justification des mesures exclues
- Rédaction de la déclaration d'applicabilité
- Autorisation de la direction de mise en œuvre du SMSI :
 - 1) Acceptation du plan de traitement du risque (y compris les risques résiduels acceptés par la direction)
 - 2) Approbation de la déclaration d'applicabilité
 - 3) Autorisation écrite de la direction quant à l'implantation du SMSI
- Modèle :

Mesure Sécurité | Applicable | DescriptionSommaire | Justification | Document | Responsable

- Déclaration d'applicabilité
- Autorisation écrite de la direction pour la mise en œuvre du SMSI

Etape 2 : Mise en œuvre et fonctionnement du SMSI (Déployer)

1 Définition de la structure organisationnelle de la sécurité de l'information

- Définir la structure organisationnelle de la gestion de la sécurité de l'information
- Définir les rôles et responsabilités des intervenants en lien avec le SMSI
- Définir les rôles et responsabilités des principaux comités :
 - 1) comité de direction (niveau stratégique)
 - 2) comité de la sécurité de l'information (niveau tactique)
 - 3) comités opérationnels (niveau opérationnel)

- Description des rôles et responsabilités des intervenants en lien avec le SMSI
- Description du fonctionnement des principaux comités liés au SMSI

Etape 2 : Mise en œuvre et fonctionnement du SMSI (Déployer)

2 Définition du processus de gestion documentaire

- Création de modèles de documents.
 - Définition d'une procédure de maîtrise des documents.
 - Mise en œuvre d'un système de gestion documentaire.
 - Définition d'une procédure de maîtrise des enregistrements.
 - Création d'une liste principale des documents reliés au SMSI
- ➔ intégré à la DdA: document unique qui regroupe la description des mesures de sécurité ainsi que la documentation qui est relié

- Procédure de maîtrise des documents
- Système de gestion documentaire
- Procédure de maîtrise des enregistrements

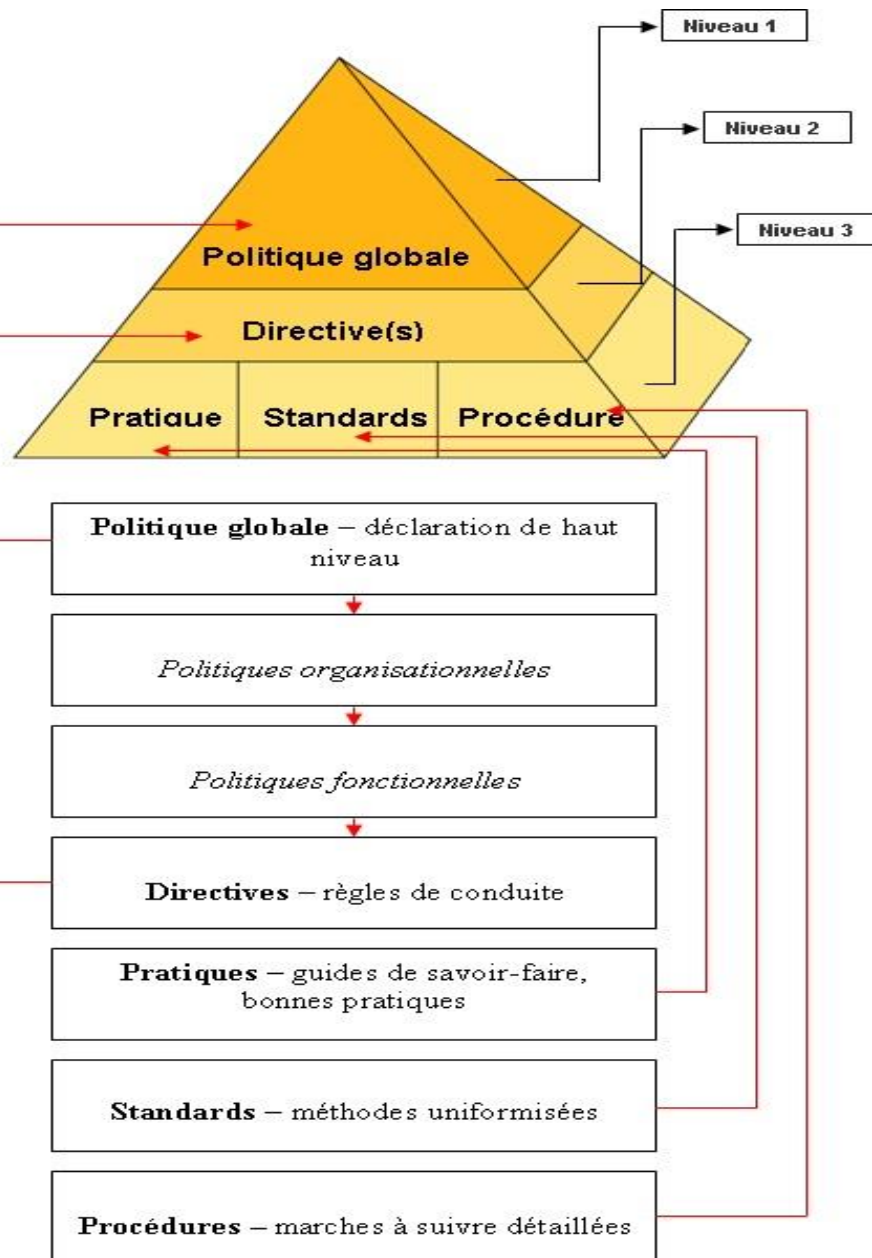
Etape 2 : Mise en œuvre et fonctionnement du SMSI (Déployer)

3 Conception des mesures de sécurité et rédaction des politiques spécifiques et procédures

- Conception des processus et mesures (effectuer le design)
- Description des processus et mesures : documentation des différentes mesures de sécurité liées au SMSI
- Rédaction des politiques spécifiques : en fonction des mesures de sécurité sélectionnées
 - ➔ 9 politiques spécifiques mentionnées dans l'annexe A de l'ISO 27001
- Rédaction des procédures
 - ➔ 6 procédures explicitement exigées par l'ISO 27001:
 - Procédure de gestion des incidents (4.2.2)
 - Procédure de gestion du SMSI (4.3.1g)
 - Procédure de surveillance et de réexamen du SMSI (4.2.3a)
 - Procédure de maîtrise des documents (4.3.2)
 - Procédure d'audit interne (6)
 - Procédure d'amélioration continue (8)
 - ➔ 20 procédures mentionnées dans l'annexe A

Politique de Sécurité :

Expression des besoins, des objectifs et des directives de sécurité



Procédures opérationnelles

- la mise à jour des documents de la politique de sécurité et des procédures
- l'attribution des responsabilités
- autorisation pour l'ajout d'outil de traitement de l'information
- classification des ressources
- sécurité physique (contrôle des accès physiques, sécurité des équipements hors des locaux, mise au rebut des équipements, ...)
- développement, test et déploiement des applications
- sous-traitance
- gestion des ressources par des tiers
- protection contre les logiciels malveillants
- sauvegarde et de restitution de données - gestion du courrier électronique
- contrôle d'accès logique (aux réseaux, aux systèmes, aux applications,...)
- chiffrement
- gestion des journaux (logs)
- gestion des modifications
- gestion des versions
- gestion des incidents
- continuité des activités

Etape 2 : Mise en œuvre et fonctionnement du SMSI (Déployer)

3 Conception des mesures de sécurité et rédaction des politiques spécifiques et procédures

- Définition des enregistrements :

- Créer une liste des enregistrements associés aux processus et mesures de sécurité.
- Décrire comment seront gérés les enregistrements
- Créer les formulaires et les autres supports destinées à recueillir et à conserver les enregistrements (lors de la rédaction des procédures)

- Politiques spécifiques en sécurité de l'information
- Procédures liées aux processus et mesures de sécurité

Etape 2 : Mise en œuvre et fonctionnement du SMSI (Déployer)

4 Formation, sensibilisation et communication

- Mise en œuvre du processus de gestion du programme de formation, sensibilisation et communication
- Evaluation des besoins en compétences
- Elaboration du programme de formation (acquérir des compétences)
- Elaboration du programme de sensibilisation (changer les habitudes)
- Elaboration du programme de communication (Informer)
- Planification des activités de formation, sensibilisation et communication (le plan) : il sert également d'enregistrement

- Programmes de formation, sensibilisation et de communication
- Plans de formation, sensibilisation et de communication

Etape 2 : Mise en œuvre et fonctionnement du SMSI (Déployer)

5

Mise en œuvre des processus et mesures de sécurité

- Planifier la mise en œuvre
- Mise en œuvre des processus et mesures de sécurité
- Revue de la documentation
- Approbation par le responsable du processus et mesure de sécurité

- Processus et mesures de sécurité en place dans l'organisme, prêts à être mis en opération
- Documentation à jour

Etape 2 : Mise en œuvre et fonctionnement du SMSI (Déployer)

6 Gestion des opérations du SMSI

- Planification de la gestion du changement : Prévoir un plan de communication pour les usagers, opérateurs et les responsables des processus avant le transfert aux opérations
- S'assurer de former le personnel impliqué dans les opérations avant de transférer les activités
- Transfert du projet SMSI aux opérations de l'organisme, lorsque l'équipe de projet SMSI a terminé la mise en œuvre des processus et mesures de sécurité
- Gestion des ressources nécessaires au maintien et à l'amélioration du SMSI dans une perspective de long terme (budget, personnel qualifié et matériels nécessaires)

Processus et mesures de sécurité liés au SMSI
gérés efficacement par les opérations de
l'organisme

Etape 3 : Surveillance et réexamen du SMSI (Contrôler)

1

Mesure du SMSI

- Détermination des objectifs de mesure : des objectifs à différents niveaux : stratégique, tactique et opérationnel
 - Développement du programme de mesure de la sécurité de l'information
 - Identification des besoins en information et détermination des objets de mesure
 - Développement des indicateurs
 - Documentation des indicateurs
 - Création de tableaux de bord (opérationnel, tactique et stratégique)
- ➔ ISO 27004 : code de bonne pratique pour la mesure de l'efficacité d'un SMSI ou le guide de NIST

Indicateurs et tableaux de bord en sécurité de l'information

Etape 3 : Surveillance et réexamen du SMSI (Contrôler)

2 Audit interne

- Création du programme d'audit interne
- Nomination du responsable d'audit interne
- Etablissement de l'indépendance, l'objectivité et l'impartialité
- Planification des activités d'audit
- Allocation et gestion des ressources
- Création des procédures d'audit
- Réalisation des activités d'audit
- Suivi des non-conformités

- Procédures d'audit
- Rapport d'audit interne
- Rapport de suivi des non-conformités

Etape 3 : Surveillance et réexamen du SMSI (Contrôler)

3 Revue de direction

➔ Evaluations régulières et méthodiques de la pertinence, de l'adéquation, de l'efficacité et (peut également inclure) l'efficience (optimisation des mesures) du SMSI par rapport aux politiques et aux objectifs de sécurité de l'information de l'organisme

- Préparation d'une revue de direction
- Conduite d'une revue de direction
- Conclusion d'une revue de direction
- Suites à une revue de direction

- Mise à jour des politiques, du plan d'appréciation du risque et du plan d'amélioration du SMSI approuvés par la direction
- Approbation de l'allocation des ressources

Etape 4 : maintien et amélioration du SMSI (Agir)

1

Amélioration continue

- Définir un processus d'analyse des causes intrinsèques. L'analyse des causes intrinsèques est une méthode de résolution des non-conformités basée sur l'identification des causes originelles d'un problème ou d'un événement.
- Procédure d'action corrective (éliminer définitivement les causes intrinsèques d'une non-conformité ou de tout autre événement indésirable existant et pour empêcher leur renouvellement).
- Procédure d'action préventive (éliminer les causes de non-conformités potentielles)
- Dépôt de plans d'action suite à un audit :
 - un plan d'action doit être soumis pour chaque non-conformité et non un plan d'action global
 - Doivent être approuvés par la direction

- Procédures d'action corrective et préventive
- Plans d'action

Etape 5 : Préparation à l'audit de certification

- Choix de l'organisme de certification
- Préparation à l'audit:
 - 1) Auto-évaluation
 - 2) Préparation du personnel
 - 3) Audit à blanc
- Audit d'étape 1 :
 - 1) Vérifier le « design » du SMSI
 - 2) La revue des documents est la principale activité de l'étape 1.
 - 3) Habituellement, 30% du temps total est consacré à l'audit d'étape 1 (2 à 4 semaines).
- Audit étape 2 (audit sur site) : mesurer l'efficacité du SMSI et des mesures de sécurité.
- Audit de suivi (s'il y a lieu, pour réviser les non-conformités) : une non-conformité majeure devrait habituellement impliquer un audit de suivi.
- Décision de certification

Etape 5 : Préparation à l'audit de certification

- Préalable à l'audit :

- 1) Un SMSI doit être en opération depuis au moins d'un délai de 3 mois afin de s'assurer d'avoir un historique de fonctionnement.
- 2) Au minimum un rapport d'audit interne doit être effectué ainsi qu'une revue de direction.

Certification ISO 27001

Schéma de certification ISO 27001

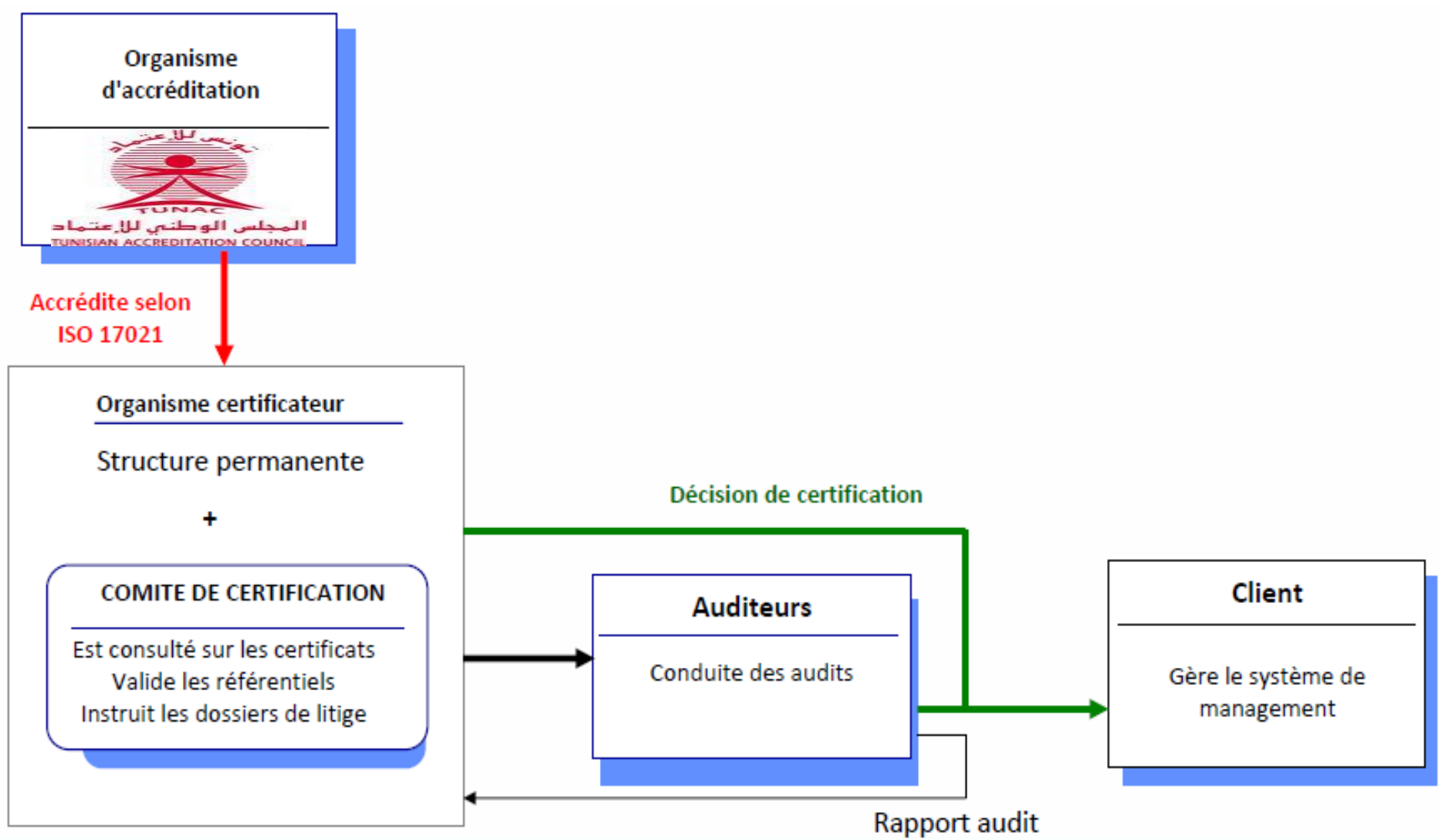


Schéma de certification ISO 27001



Retour d'expérience

- Le RSI est souvent le chef de projet SMSI
- Le RSI est le responsable SMSI : responsable de la gestion des opérations du SMSI après sa mise en œuvre
- Intégrer le SMSI dans les processus existants
- Eviter l'intégration de nouvelles technologies : concevoir le système initial avec les technologies déjà en place dans l'organisme (technologies minimales nécessaires)
- Commencer par un domaine d'application réduit lié au cœur de métier
- Avec un système de management existant, la durée d'exécution d'un projet SMSI est réduite d'une façon notable
- Durée provisoire d'un projet SMSI : sondage « ISO 27001 Global Survey 2008, Certification Europe » sur 312 entreprises certifiées ISO 27001 :
 - * Durée < 12 mois : 60%
 - * Durée < 6 mois : 20% un autre système de management est déjà mis en place
 - * PME :
 - Durée moyenne : 6 à 12 mois
 - 3-4 personnes à temps partiel : 35 à 60 H/J
 - * Grandes entreprises :
 - Durée moyenne : 12 à 18 mois
 - 2 personnes dédiées à temps plein + nombreux collaborateurs de façon ponctuelle



Audit de la Sécurité

Besoin

- Evaluer
- Améliorer
- Certifier
- Analyser sur incident
- Sensibiliser

Input

- Un périmètre
- Un référentiel
- Une méthode
- Des moyens
et des compétences

Comment?



Output

- Des écarts
- Des recommandations
- Un label